

NAME: Mary Nyambura Gitau
GMAIL:marynyambura657@gmail.com
ADMISSION NUMBER: CS-SA12-26067

INTRODUCTION TO WEB APPLICATION

In this module, I will cover the fundamentals of HTML, CSS, and JavaScript, and learn how these core web technologies work together to build web applications.

1.1 Introduction

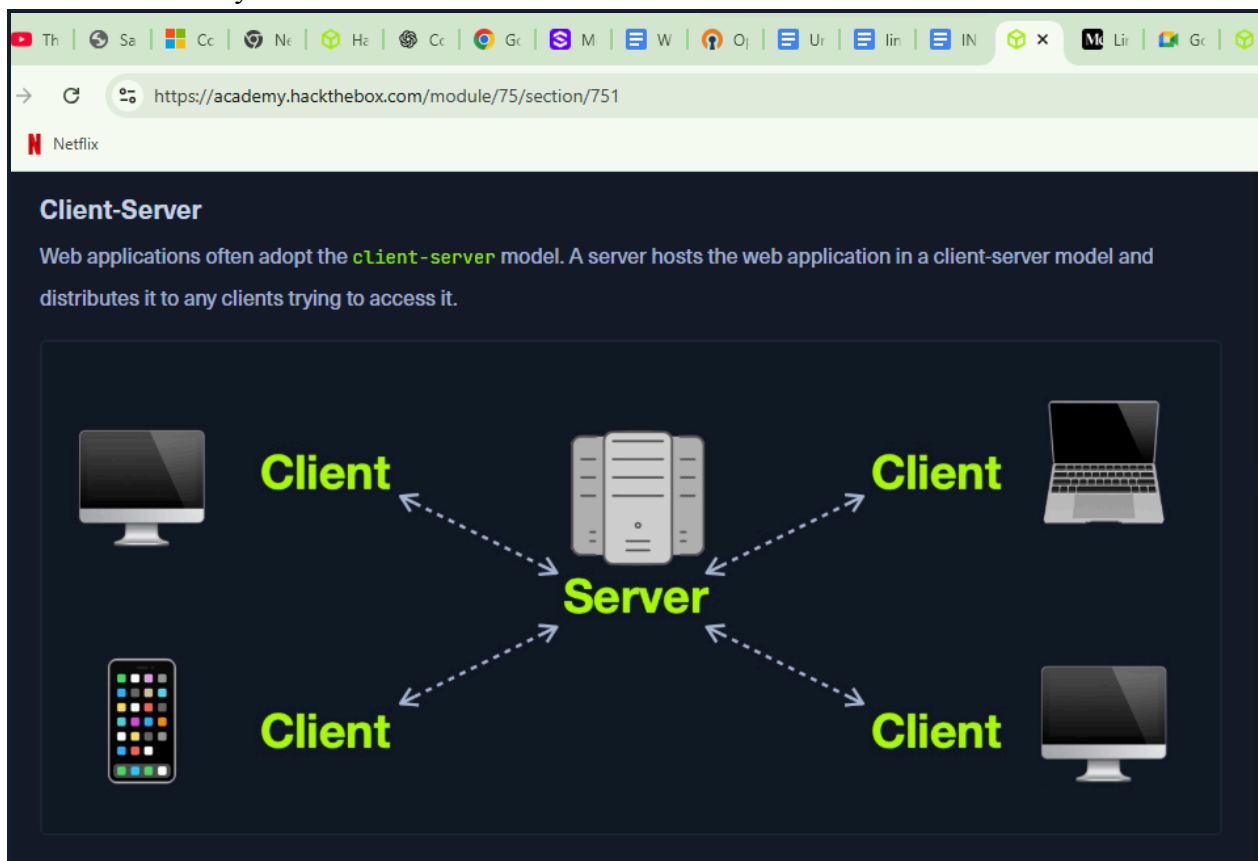
Web application is an application program that is stored on remote servers and delivered through the internet through a browser interface.

1.2 Web application Layout

Web applications have different models :

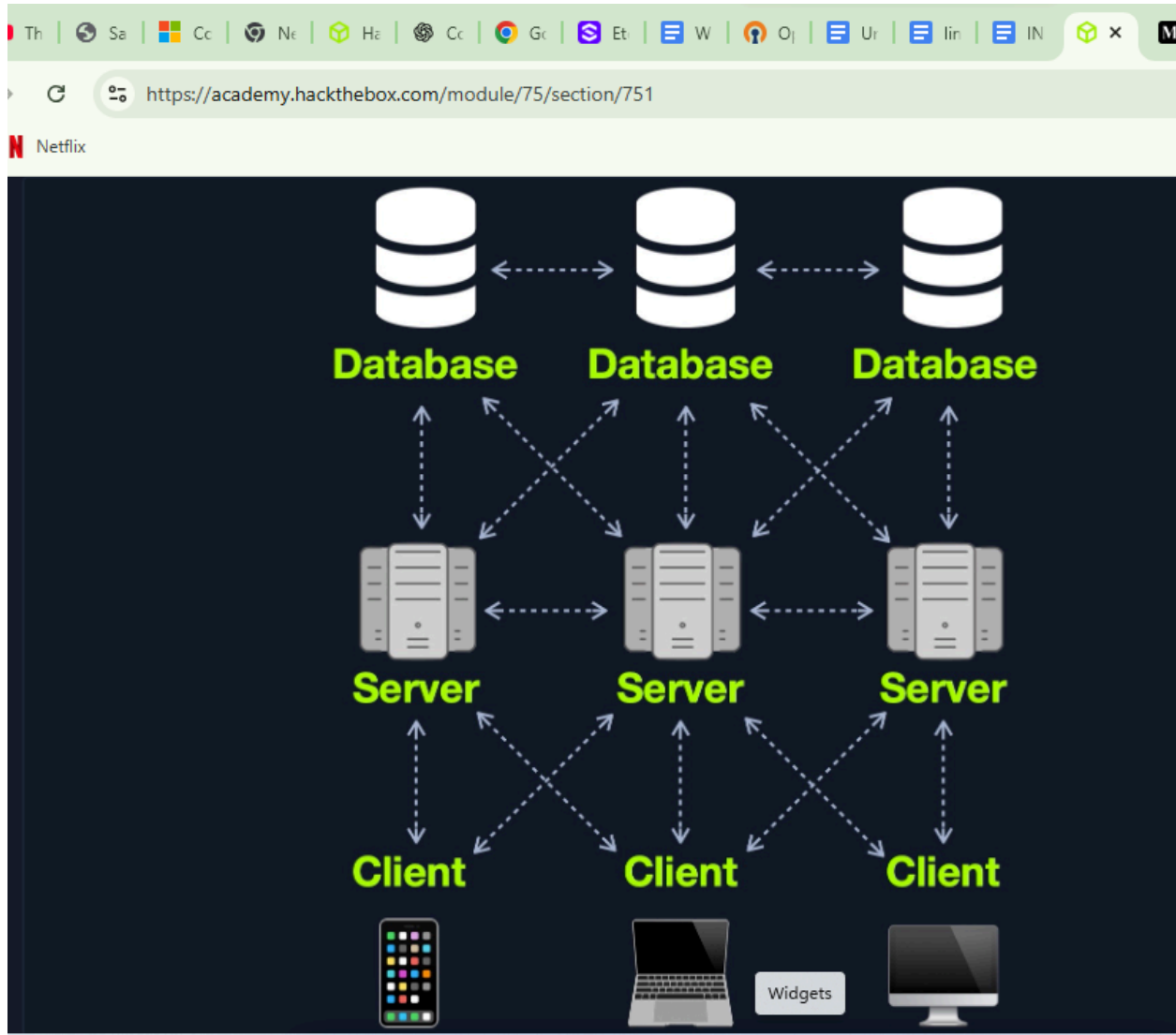
- a) **Client Server** is a server that hosts the web application in a client-server model and distributes it to any clients trying to access it. I learnt that web applications have different architecture.

There are three main architectures including: client-server, one-server, many servers, one database and many servers.



b) Many servers-Many databases

This model mainly caught my attention as when there is power outage there are many backups to take up tasks. Also this model reduces redundancy because of the load balancing feature due to many servers.

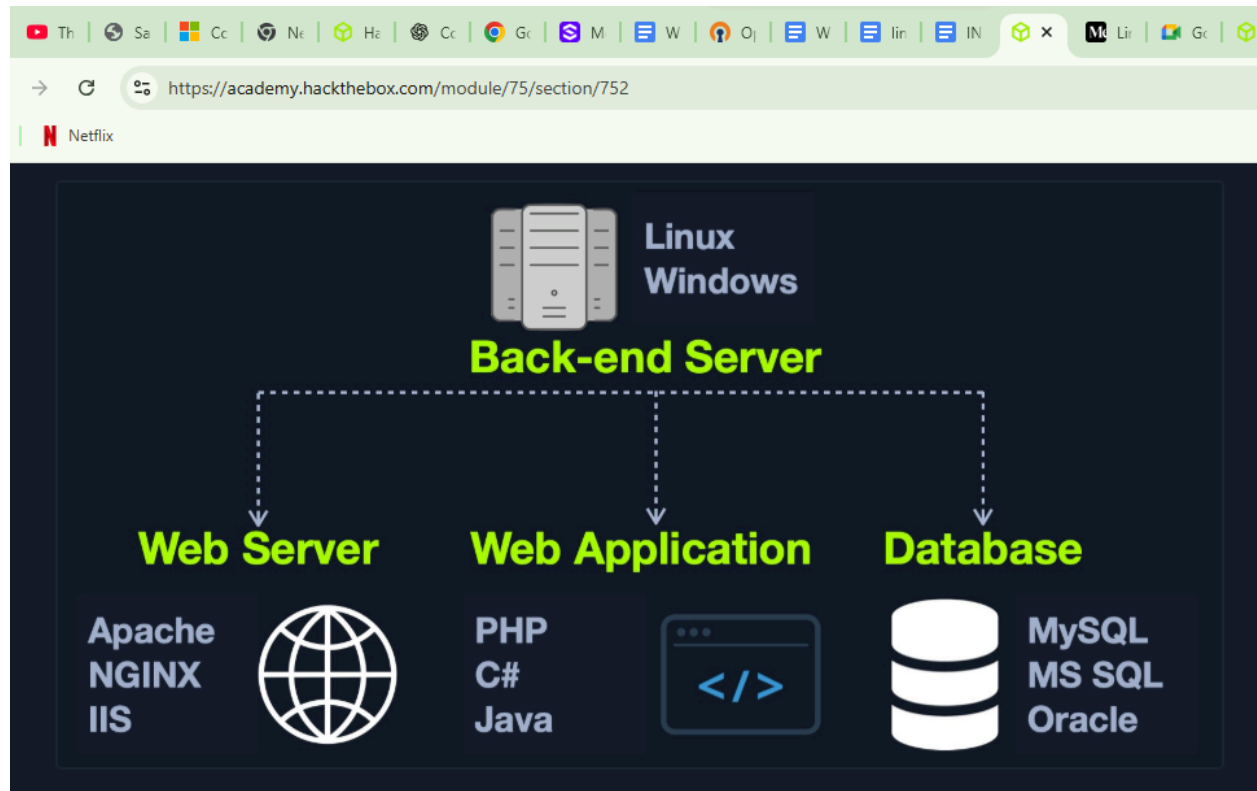


1.3 Frontend

Front end is what the user interacts with through the web browser. HTML is the hypertext mark up language that records the text, CSS is for design and animation and javascript is for functionality.

1.3.1 Backend.

Backend drives all the core functionality of a web application. Below is an illustration diagram of the backend.



1.4 Security and Vulnerabilities.

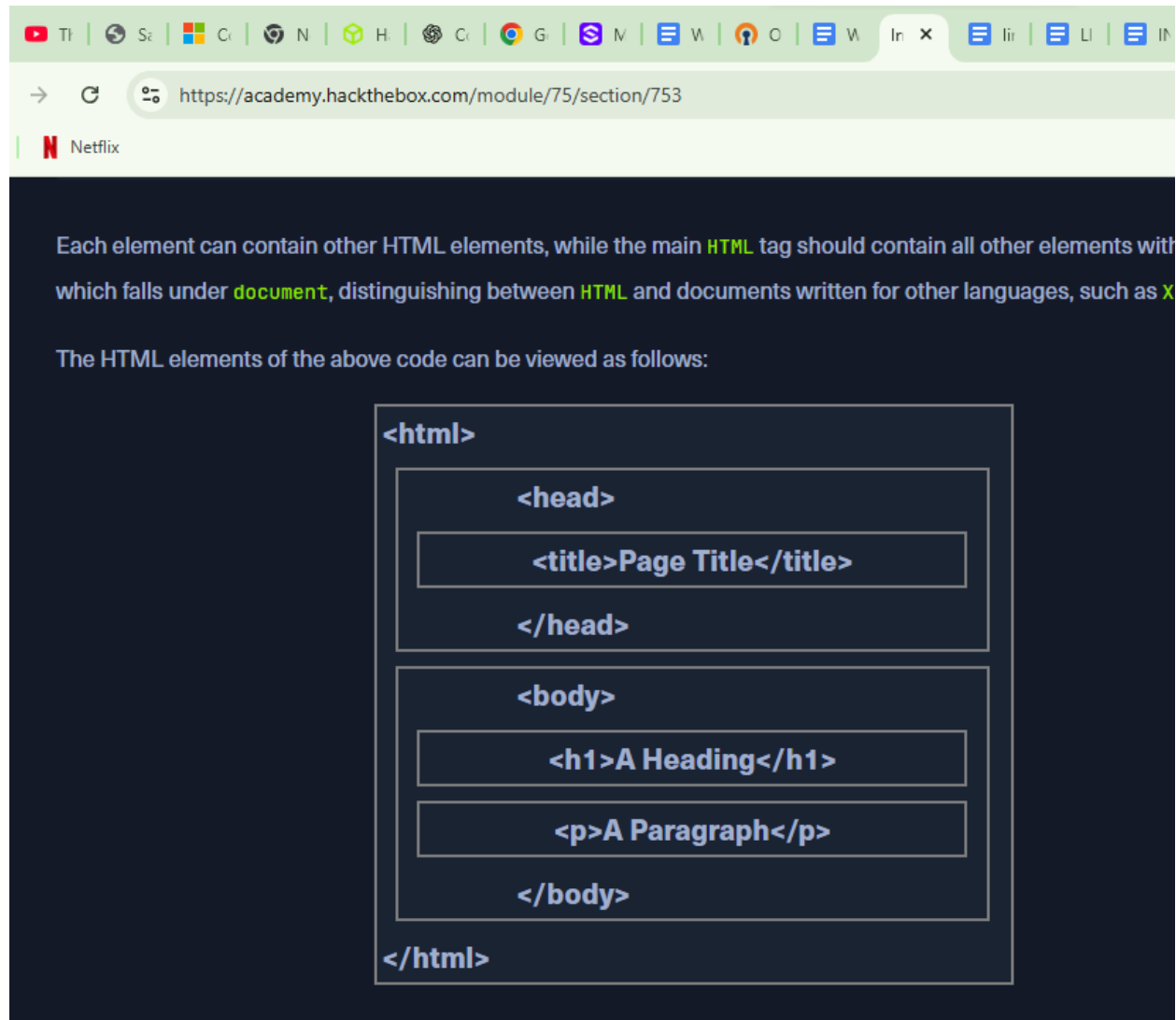
Since back end is mostly done at the back of the web application as the name suggests, most of the vulnerabilities mainly affect the source codes. eg, SQL injection and local file inclusion.

1.5 HTML

HTML-hyper text markup language is the text part of any web application .It is what users see on the interface of any application.i.e the titles, headings,forms and images.

1.6 HTML structure

This is the format in which HTML appears , below is an illustration.

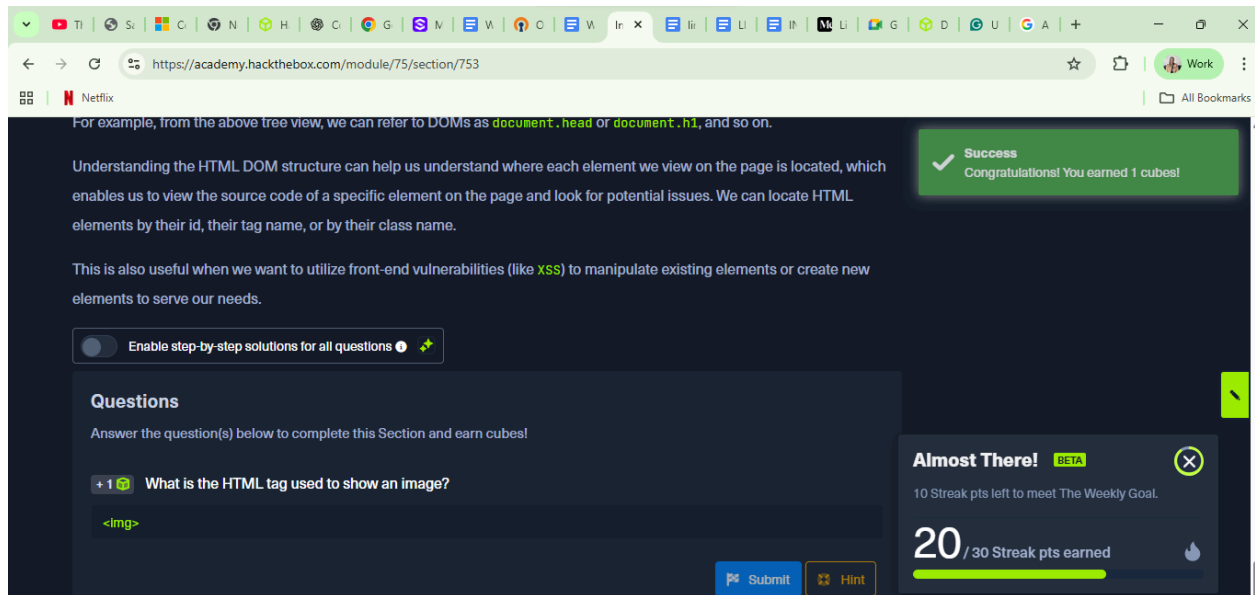


I know that all the HTML tags need to be opened and closed by `<>`. But what unique information I learnt was on the DOM. I learnt that the DOM can be classified as the HTML DOM, XML DOM and Core DOM. DOM is a platform and language-neutral interface that allows programs and scripts to dynamically access and update the content, structure, and style of a document as defined by the W3C.

Question.

What is the HTML tag used to show an image?

Answer



1.7 Cascading Style Sheet (CSS)

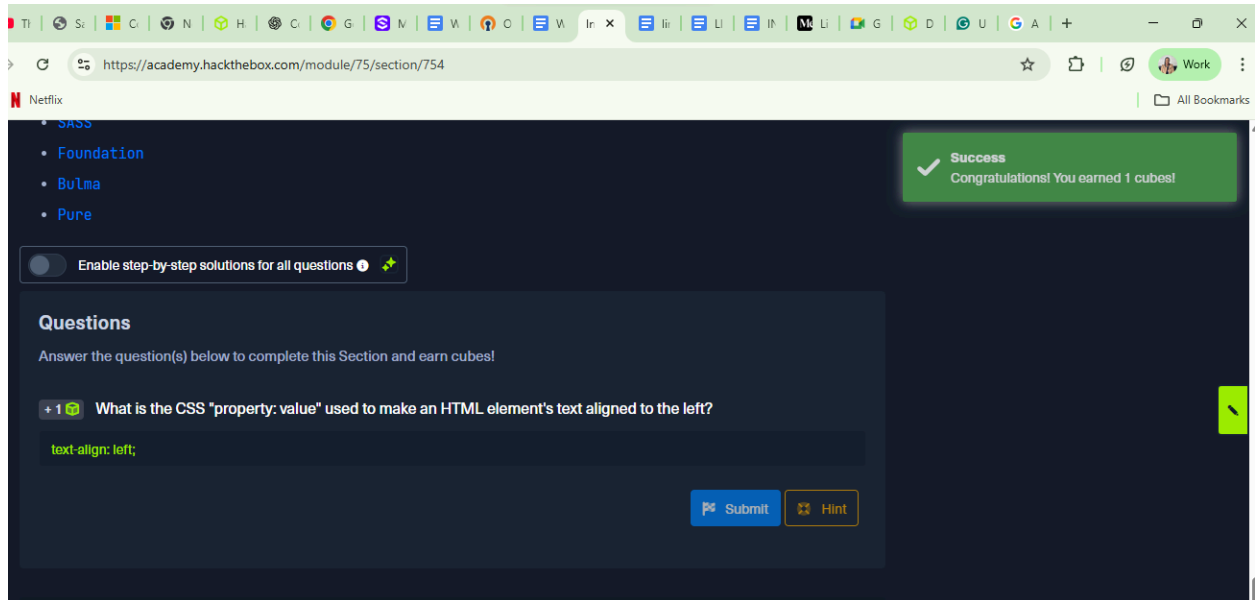
This is the aesthetic of the web application. It is used to design and add beauty to the website . Including background colour, text color and styling.

CSS syntax is (HTML element { property : value; }). There are different frameworks of css including: bootstrap, SASS, Bulma and Foundation.

Question

What is the CSS "property: value" used to make an HTML element's text aligned to the left?

Answer: text-align: left;



1.8 Javascript

Javascript handles more functionality and interactivity of the website. It is where the logic, formula, and math belong. Javascript is loaded with the `<script>` tag.

None

```
<script src="/script.js"></script>
```

Javascript frameworks include :angular, vue, react and JQuery.

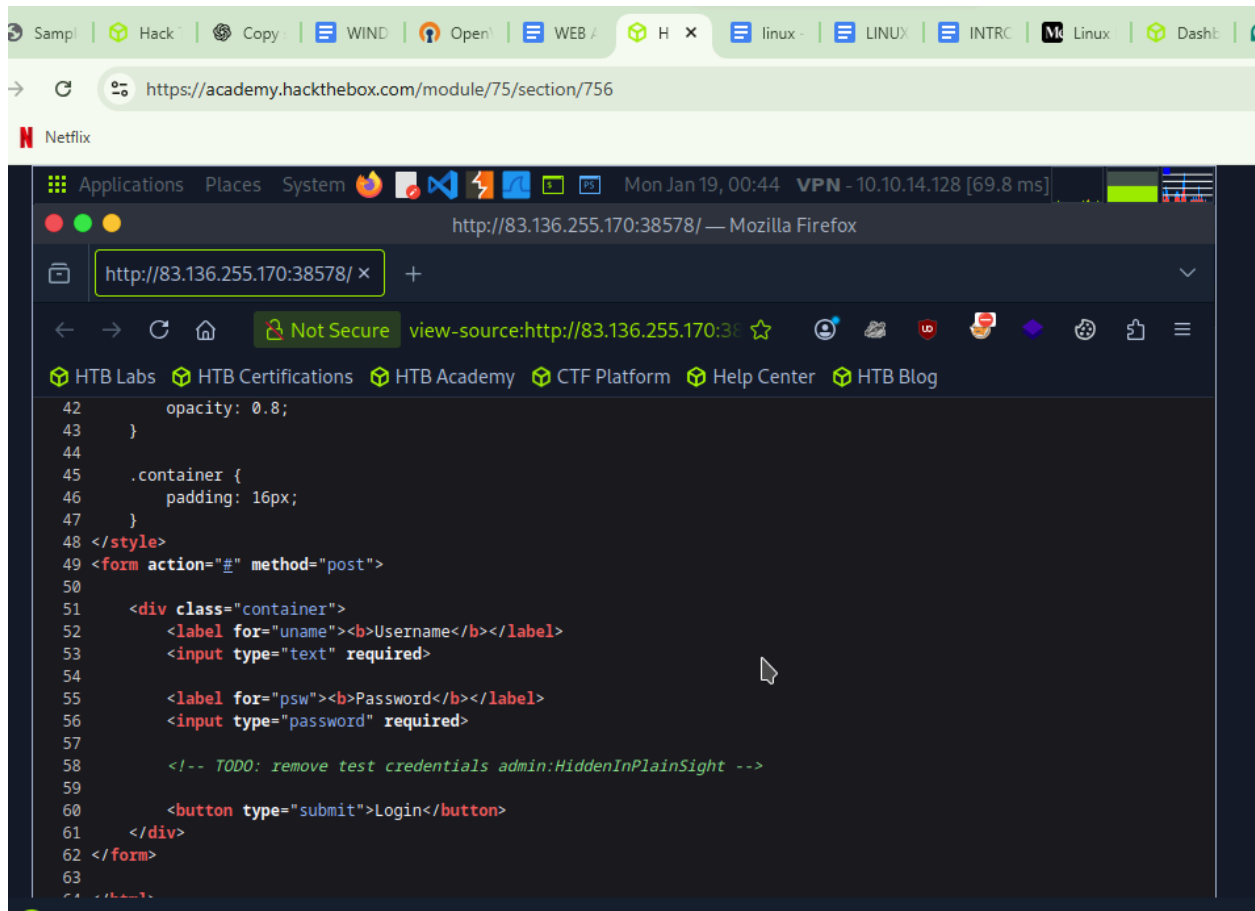
1.9 Sensitive Data Exposure

This is the availability of sensitive data to the end user. Eg, a developer may forget to delete a comment that contains a password.

Question

+ 1 Check the above login form for exposed passwords. Submit the password as the answer.

Answer: HiddenInPlainInsight



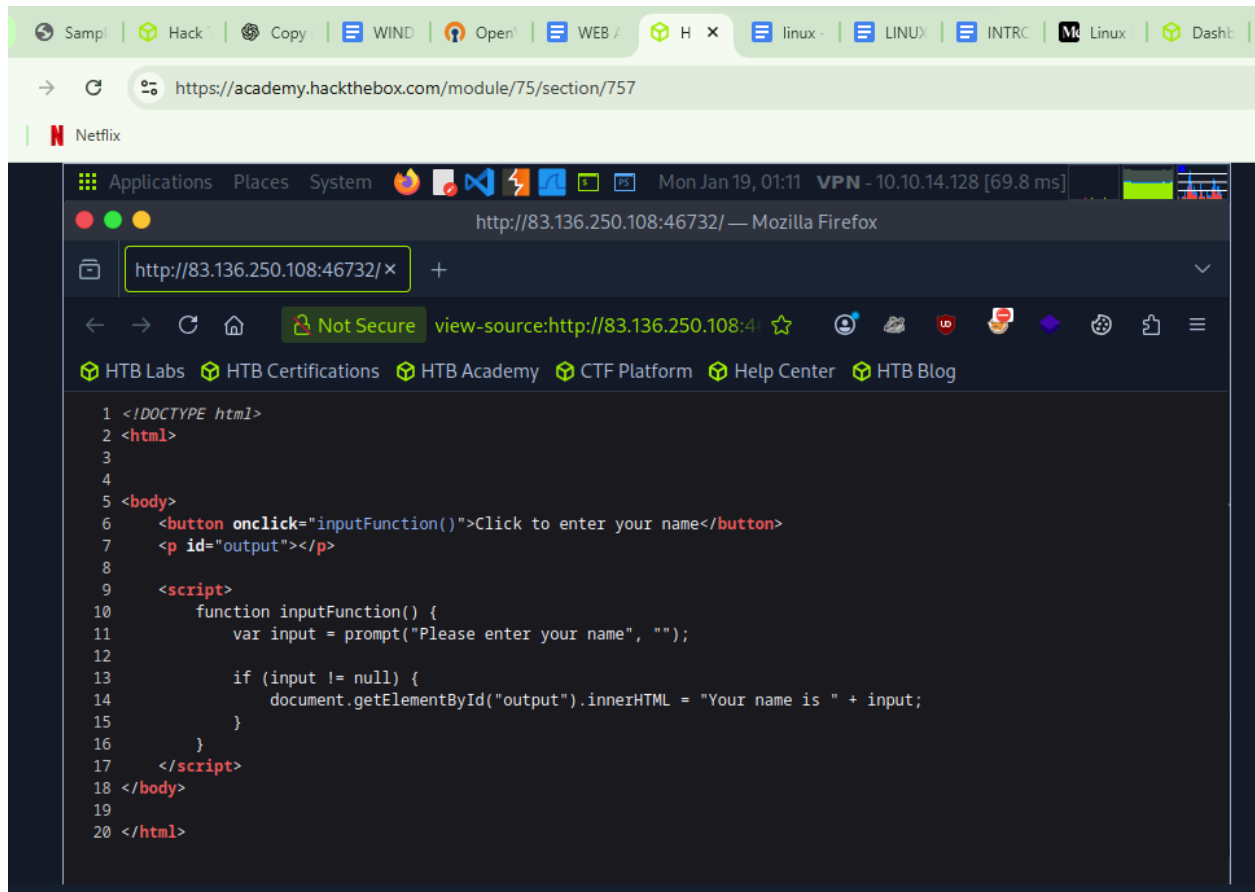
2.0 HTML injection

I learnt that HTML injection occurs when an unfiltered user input is displayed on the page
Question

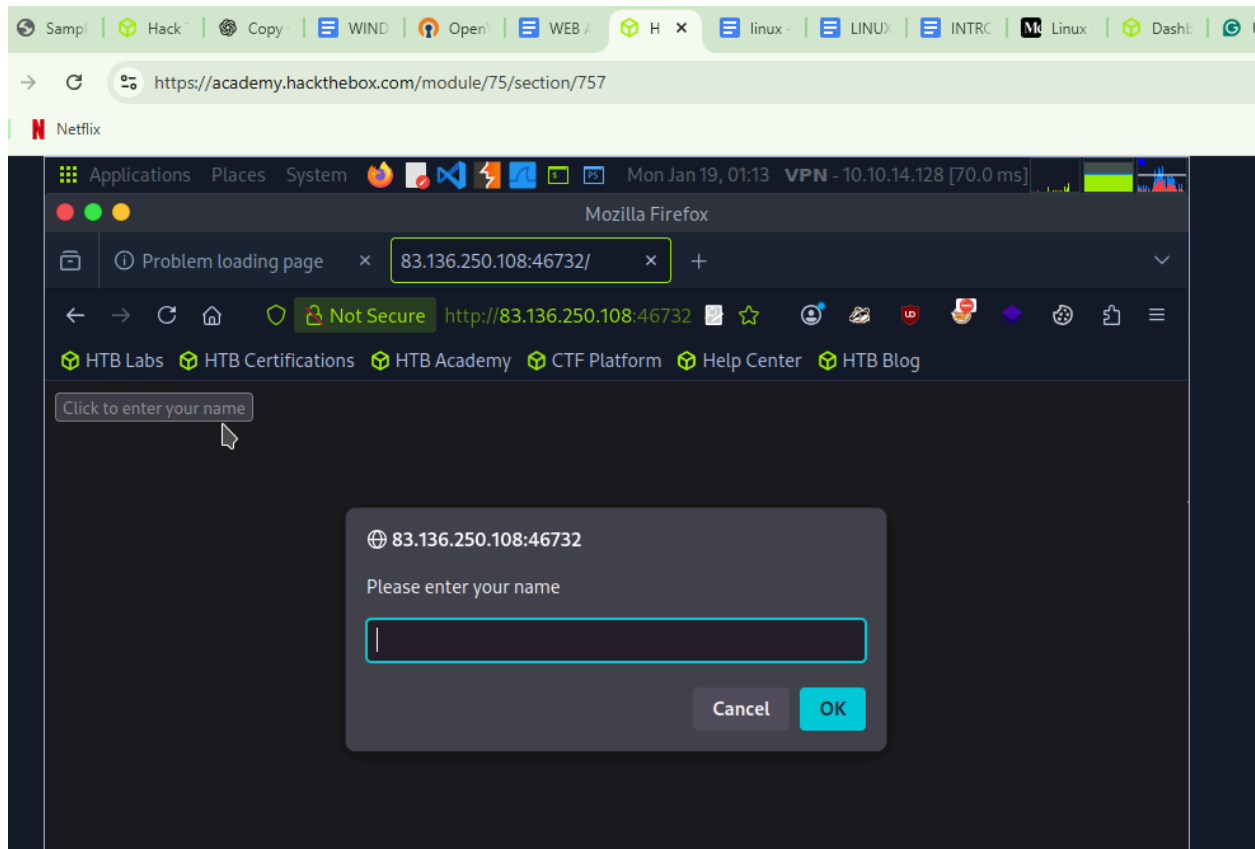
What text would be displayed on the page if we use the following payload as our input: `<a href="http://www.hackthebox.com">Click Me</a>`

Answer: Your name is Click Me

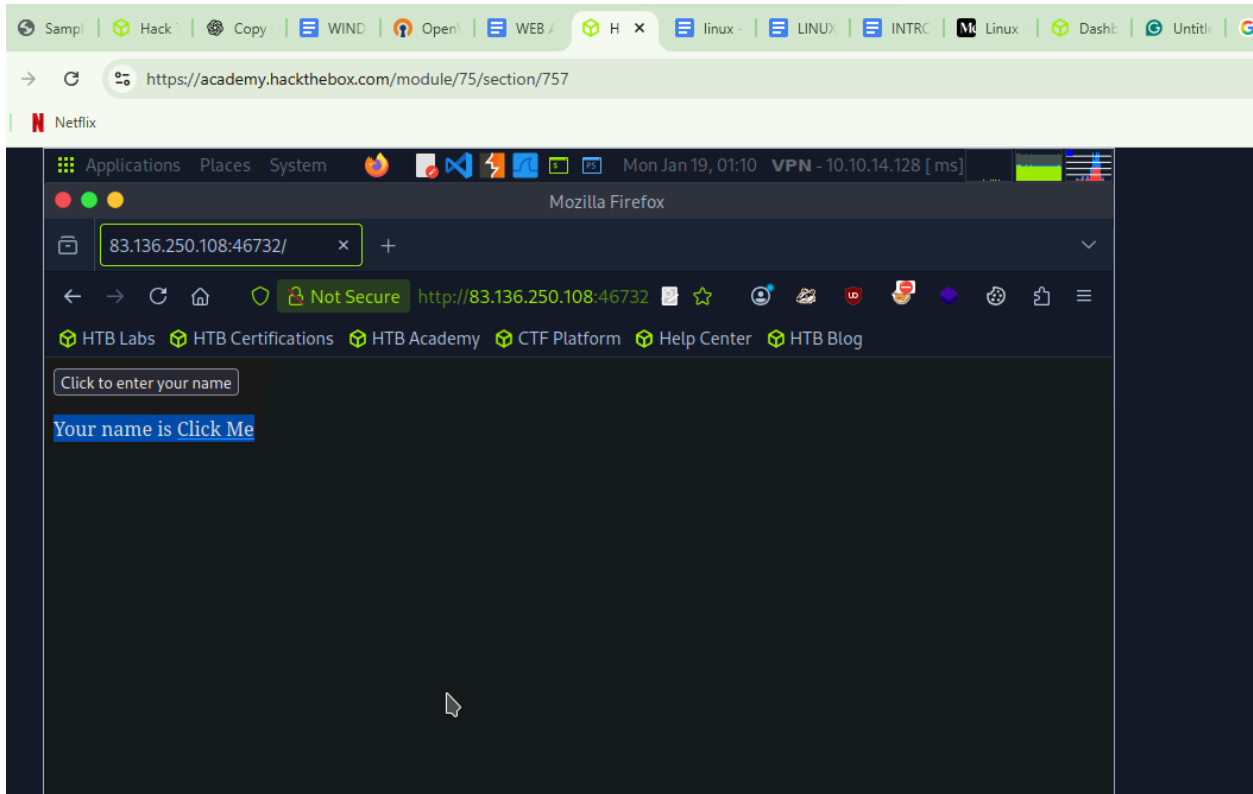
I spawned the instance and got the source code



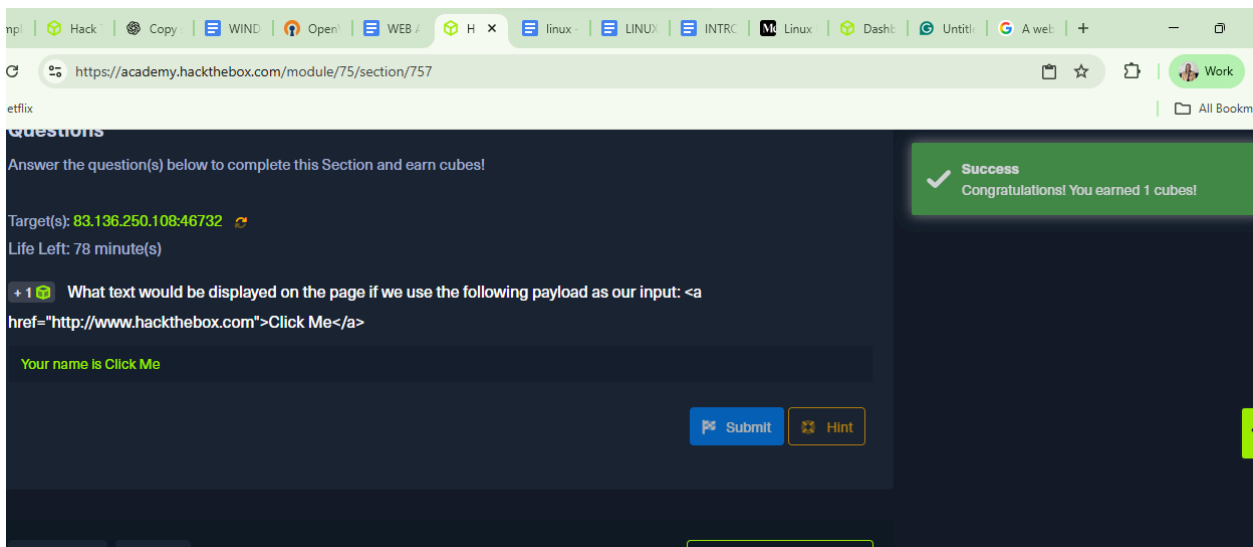
The output of the code is as shown below:



I pasted the link `<a href="http://www.hackthebox.com">Click Me</a>` to get the out put
:Your name is Click Me



Answer screenshot:



2.1 Cross Site Scripting(XSS)

I learnt that Xss is a form of HTML injection that used javascript code to be executed on the client side. I was informed of the three forms of XSS including:reflected, stored and DOM XSS.

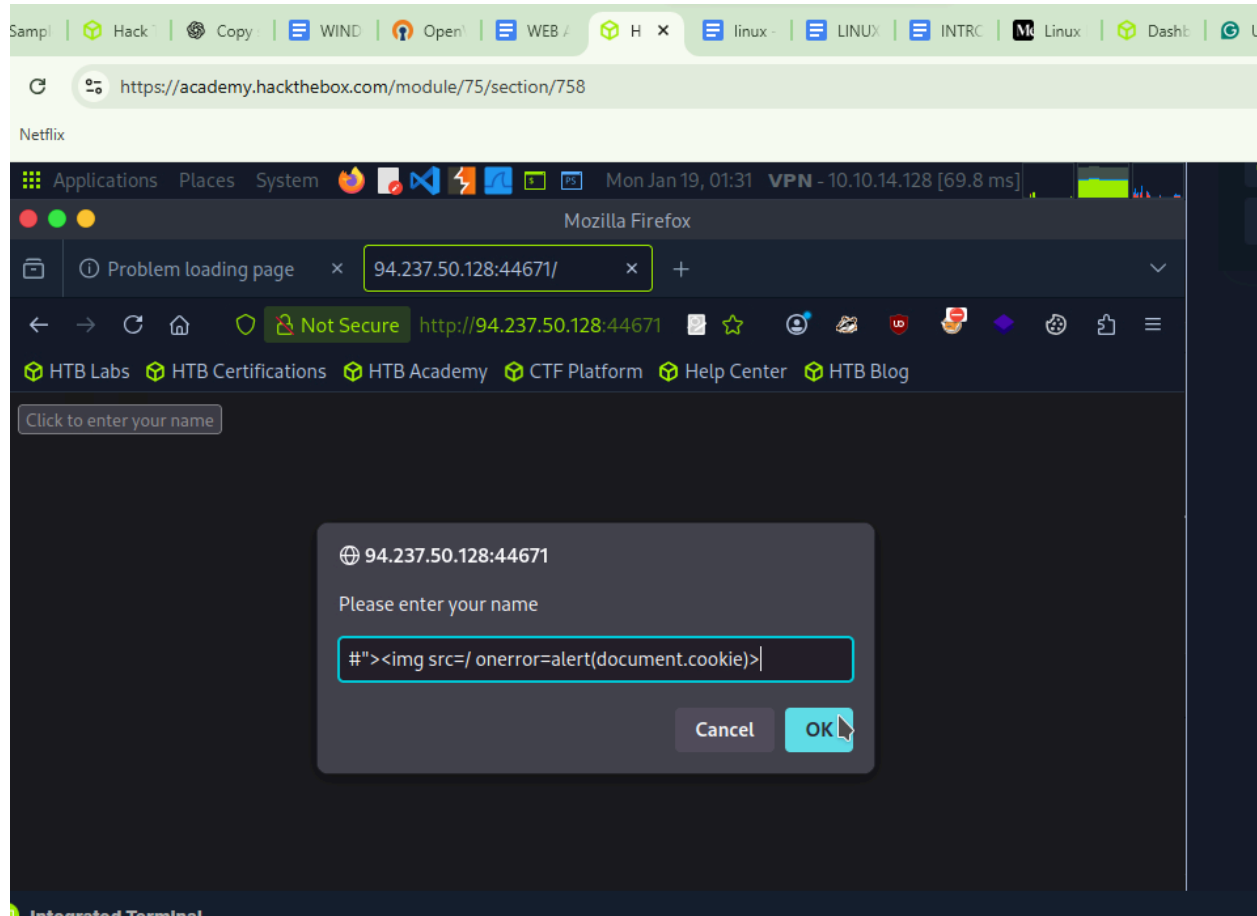
Question

- 1 Try to use XSS to get the cookie value in the above page

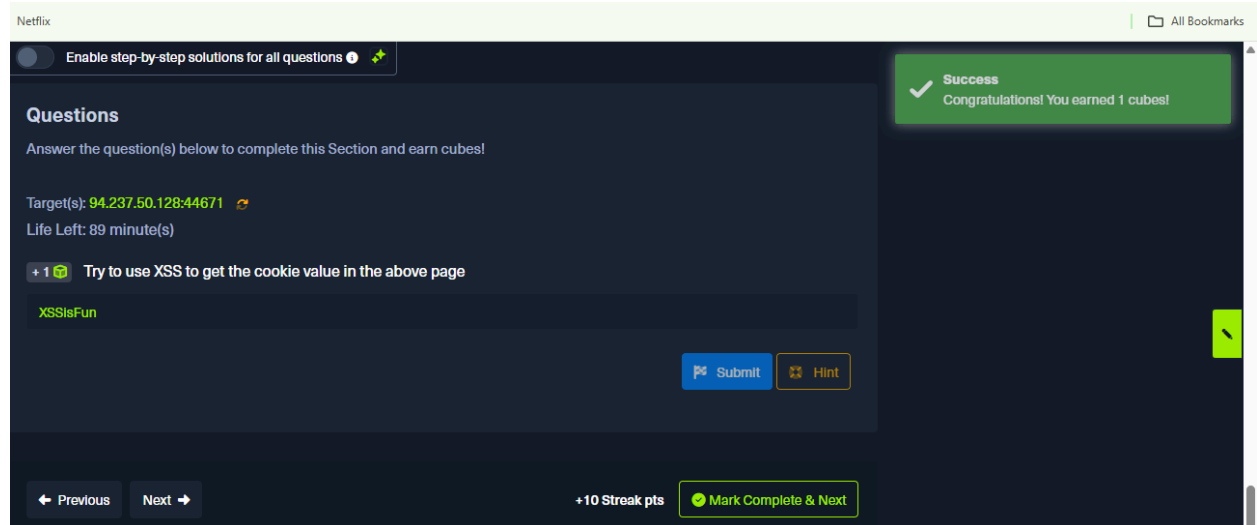
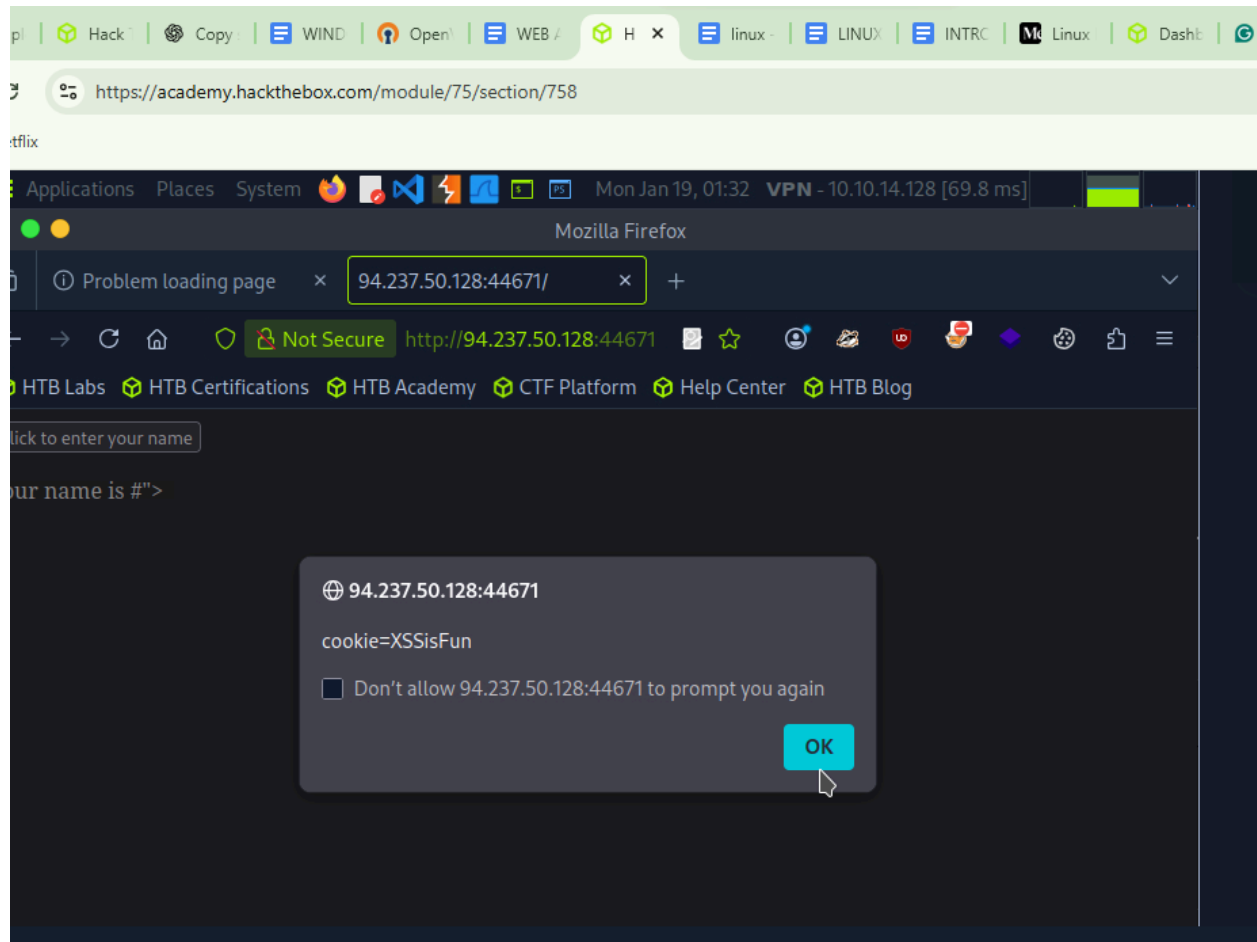
Answer:

XSSisFun

Explanation: after spawning, i copied the link in the button



And the cookie value is as displayed in the screenshot below.



2.2 Cross-Site Request Forgery(CSRF)

I learnt that it is a web security vulnerability where an attacker tricks a user into performing unwanted actions on a trusted website without their knowledge. This attack exploits the trust a website has in a user's authenticated session, often by embedding malicious requests in links or scripts. When the victim is logged in, the browser automatically sends authentication credentials, allowing the attacker to perform actions such as changing passwords or submitting forms without the user's consent.

I learnt the best way to avoid the attacks is by sanitizing and validating user input and displayed output, implementing the Web Application firewall and implementing anti-CSRF mechanisms.

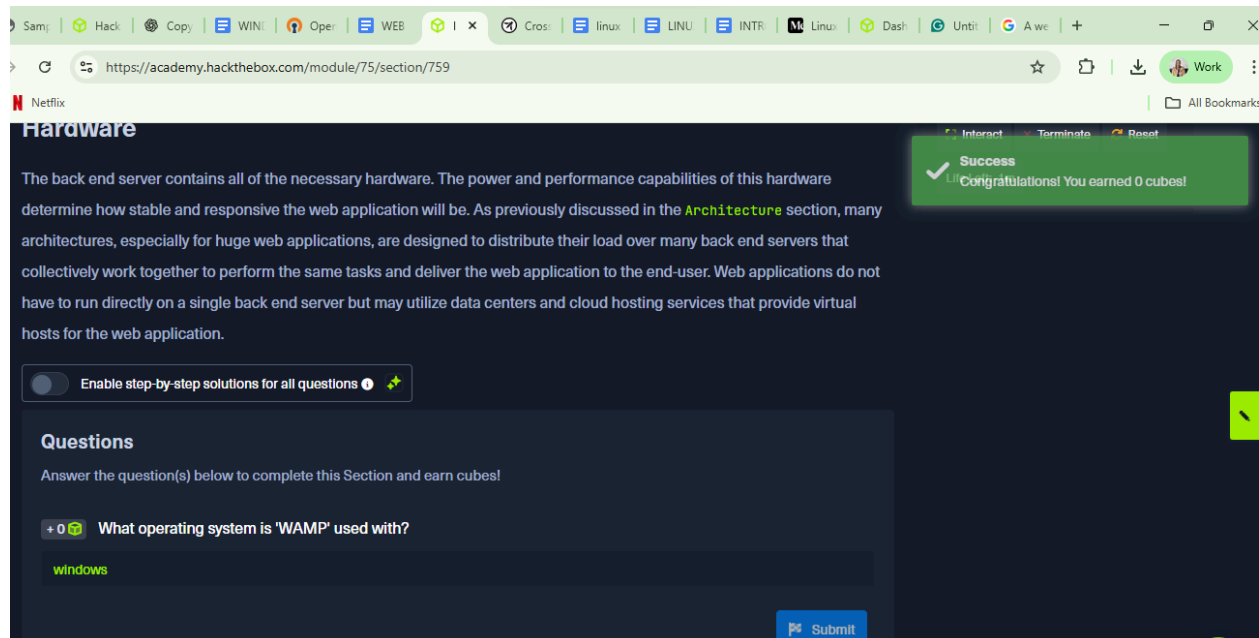
2.3 Back End Server

This refers to all the hardware and software in the back that is necessary for processes to run in the web application. Some of the back-end components include: WAMP, LAMPs, WIN and MAMP. I learnt that back end servers also have other components including web-servers, development frameworks and databases.

Question

What operating system is 'WAMP' used with?

Answer: Windows



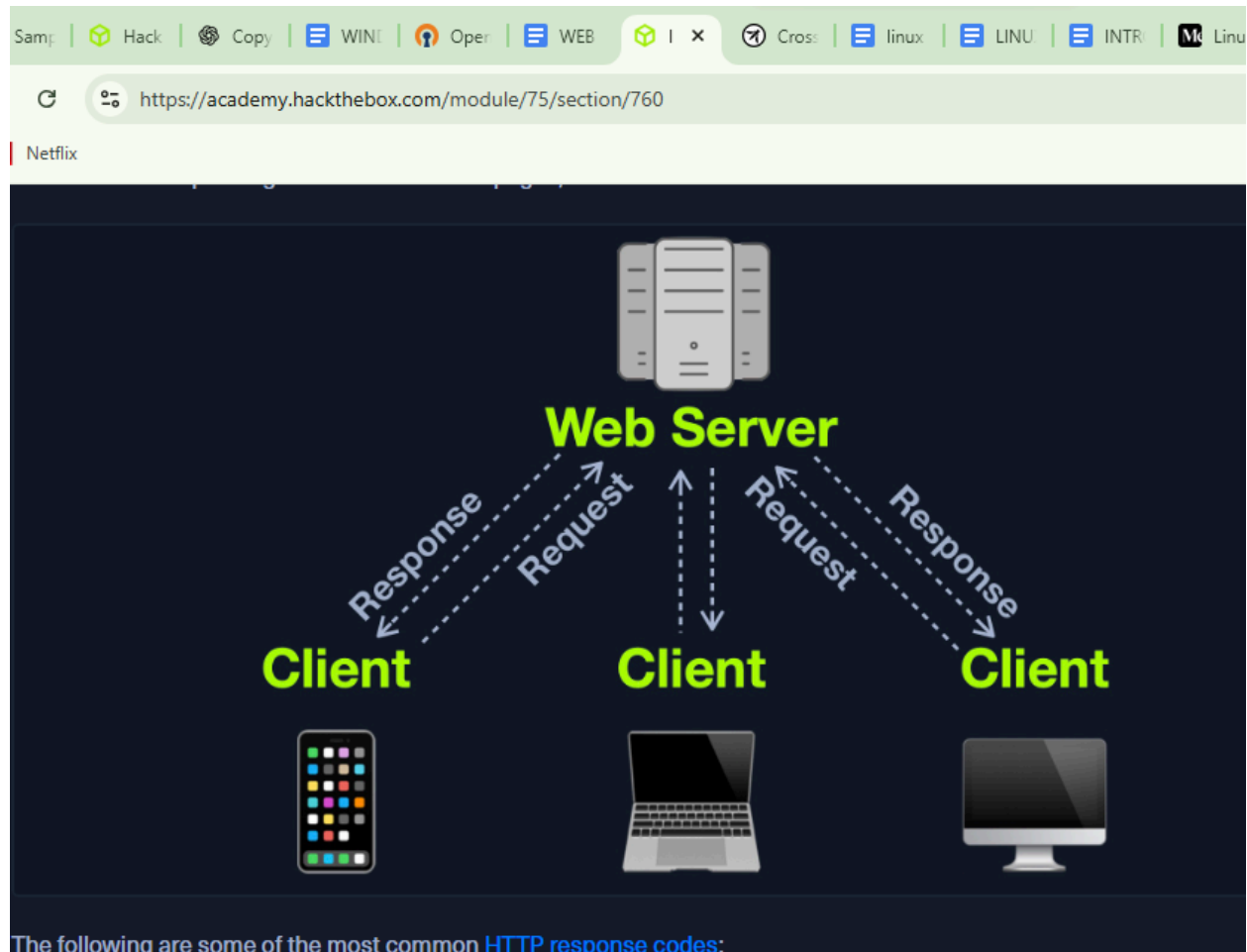
The screenshot shows a web browser window with the URL <https://academy.hackthebox.com/module/75/section/759>. The page is titled "Hardware" and contains a paragraph of text about back-end servers. A green success message in the top right corner reads: "Success Congratulations! You earned 0 cubes!". Below the text, there is a toggle switch for "Enable step-by-step solutions for all questions". Under the "Questions" section, the question "What operating system is 'WAMP' used with?" is displayed with a score of +0. The answer "windows" is entered in the text box, and a "Submit" button is visible at the bottom right.

2.4 Web Server

The web server is an application that runs on the back end server and that is responsible for taking requests from the client side and giving out responses through the client -side browser.

The webserver runs on port 80 and 443 , HTTP and HTTPS respectively.

Below is an illustration of the workflow:



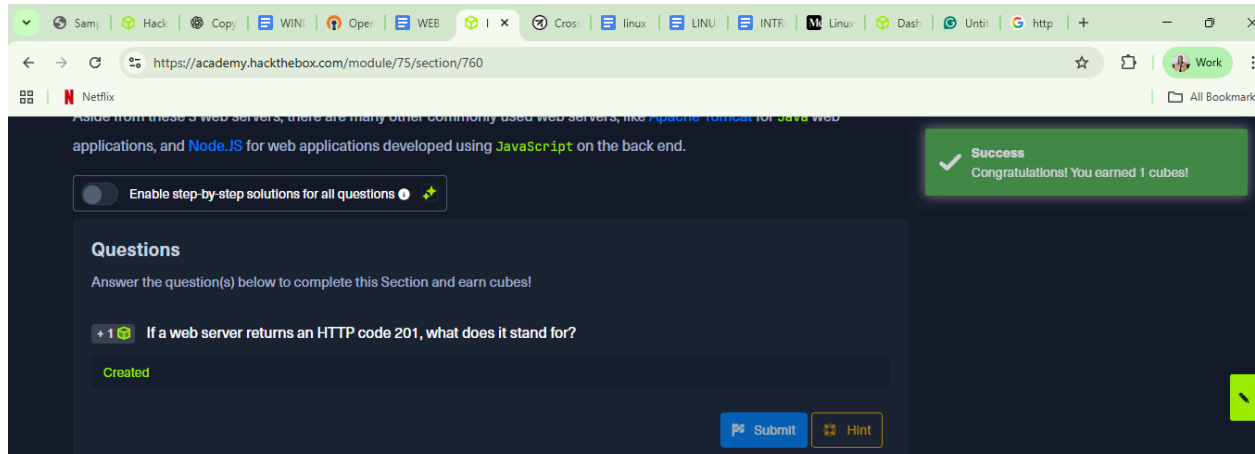
I have learnt several response codes. Successful responses=200, R edirection messages-300-
,Client error responses-400,Server error responses-500-.Examples of web servers include
:Apache, NGINX, IIS

Question

If a web server returns an HTTP code 201, what does it stand for?

Answer

Created.



2.5 Databases

Databases store various contents and information related to the web application. There are two forms of databases: relational and non-relational databases. Relational databases store their information in tables, rows and columns. These databases have a relational factor with other tables due to the use of unique keys. The relationship between tables within a database is called a Schema. Examples of relational databases are SQL, PostgreSQL and SQLite.

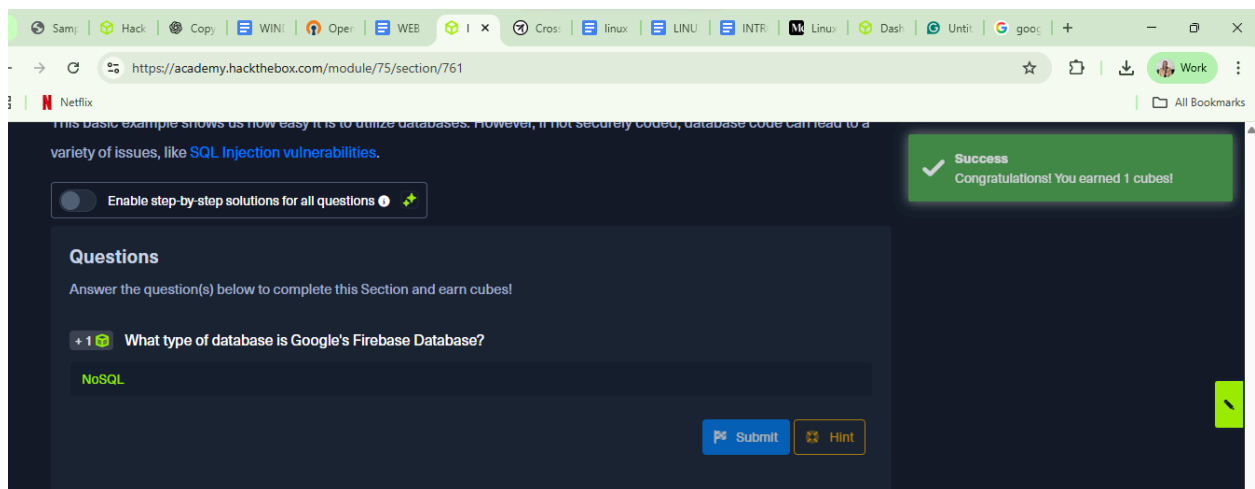
Non-relational databases store their information in Key-value, Document-Based, Wide columns and graphs. Since the databases are not relational, this set of databases is best for unstructured data. Examples of such a database include: MongoDB.

Question

1 What type of database is Google's Firebase Database?

Answer

NoSQL



2.6 Development Frameworks and API

Web development frameworks like Laravel, Django, and Rails simplify building web applications, while APIs (REST or SOAP) allow the front end and back end to communicate and exchange data efficiently.

Question

1 Use GET request `'/index.php?id=0'` to search for the name of the user with id number 1?

Answer :**superadmin**

I spawned the target, copied part of the link to the browser , then changed the value from 0 to 1.

The screenshot shows a VMware Workstation interface with a Kali Linux VM running. The browser window displays the URL `http://83.136.249.164:45915/index.php?id=1` and the response `superadmin`. Below the browser window, the Hack The Box Academy interface is visible, showing a success message: "Success Congratulations! You earned 1 cubes!". The interface also displays the target IP address `83.136.249.164:45915` and the question: "Use GET request `'/index.php?id=0'` to search for the name of the user with id number 1?". The answer `superadmin` is entered in the input field.

2.7 Common web Vulnerability

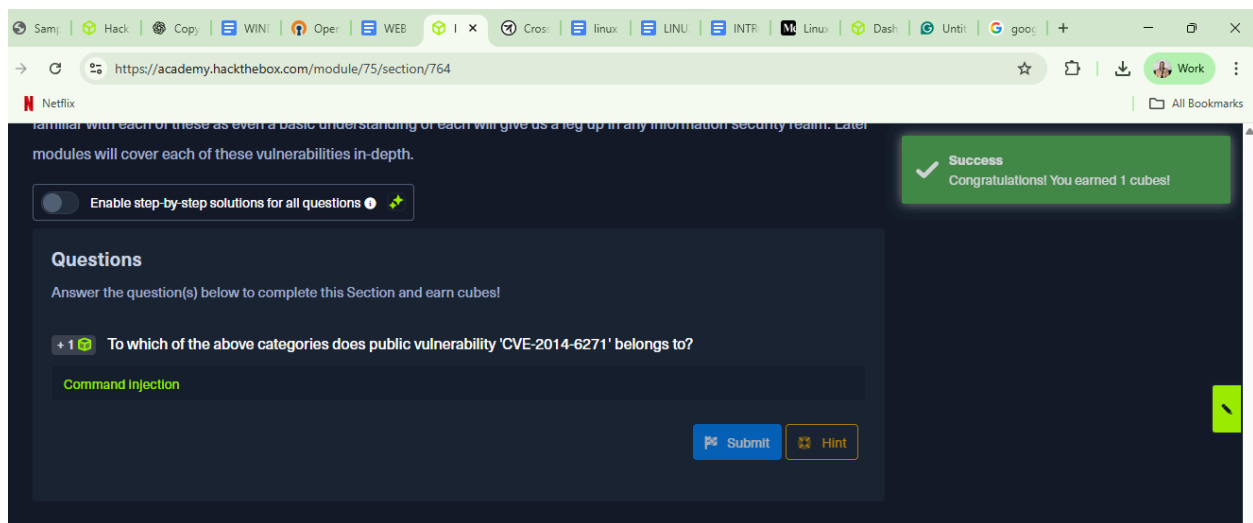
Common web vulnerabilities include broken authentication, insecure file uploads, command injection, and SQL injection, often caused by poor input validation or misconfigurations, and are part of OWASP's Top 10 risks.

Question

1 To which of the above categories does public vulnerability 'CVE-2014-6271' belong?

Answer

Command Injection.



2.8 Public Vulnerability

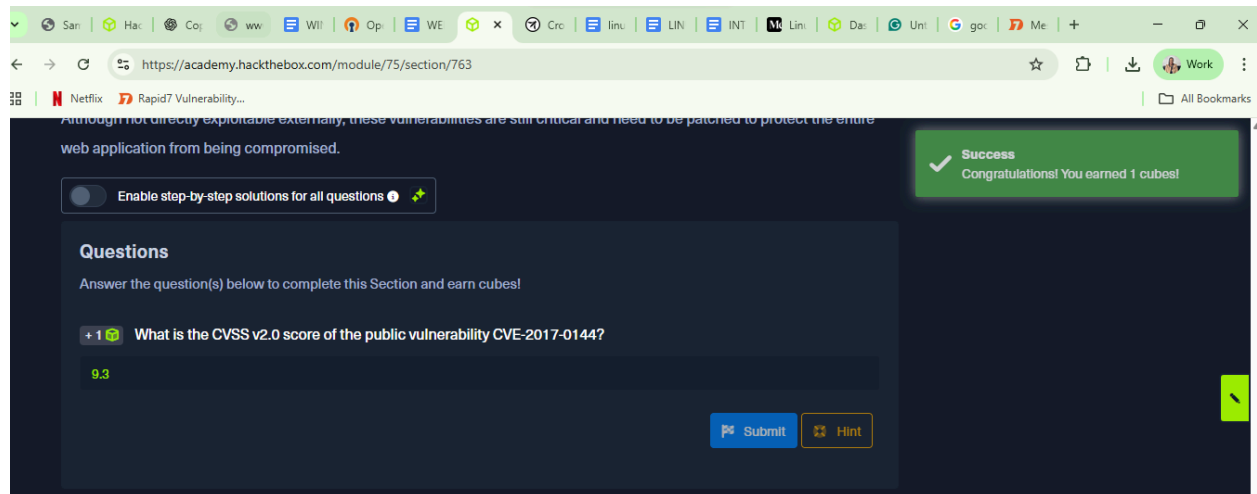
Publicly disclosed vulnerabilities (CVEs) in web applications and their back-end components can be exploited remotely, scored using CVSS to prioritize risk, and patched to prevent attackers from gaining unauthorized access or control over servers.

Question

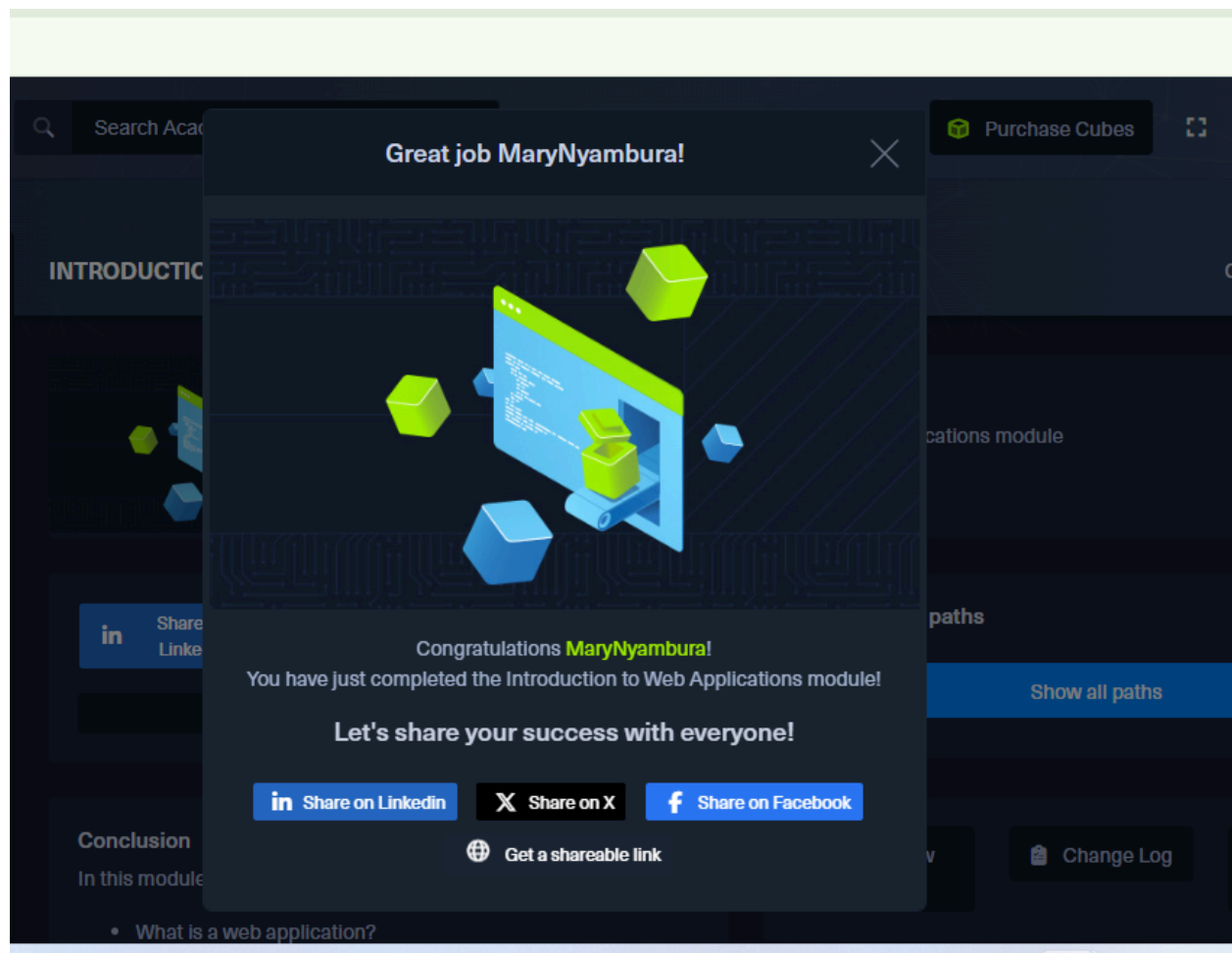
1 What is the CVSS v2.0 score of the public vulnerability CVE-2017-0144?

Answer

9.3



Below is Screenshot of my achievement on the completion of the module:



Link to the achievement:

<https://academy.hackthebox.com/achievement/2382167/75>

2.9 Conclusion and Summary

I understood the coding basics of building websites using HTML, CSS, and JavaScript, and this module further expanded my knowledge by exposing me to the risks and threats associated with how code can be exploited through various injection attacks, posing significant danger to web applications. I learned how to identify and trace these vulnerabilities and gained insight into how a security analyst detects, analyzes, and mitigates such issues to ensure web applications remain secure.